

OE-EC803C — Cyber Security

Semester VIII • 3L:0T:0P • 3 Credits

Module 4: Cyber Infrastructure Issues & International Relations

CGEC | B.Tech ECE (2023–27) | *Biraj Sarkar*

Contents

1	Critical Infrastructure Protection (CIP)	2
1.1	Key Sector Threat Profiles and Vulnerabilities	2
2	Economics, Finance, Banking & Healthcare Security	2
2.1	Economics of Cyber Security	2
2.2	SWIFT and Financial Network Security	2
2.3	Healthcare Cybersecurity Safeguards	3
3	Cyber Insurance & Risk Transfer	3
3.1	Underwriting and Actuarial Challenges	3
4	Cyber Security in International Relations	4
4.1	International Treaties and Frameworks	4

1. Critical Infrastructure Protection (CIP)

Definition: Critical National Infrastructure (CNI)

Critical National Infrastructure (CNI) encompasses physical and digital systems so vital to a sovereign nation that their disruption would severely paralyze national security, economic stability, public health, or safety.

1.1 Key Sector Threat Profiles and Vulnerabilities

Sector	Target Systems	Critical Threat Vectors
Banking & Finance	SWIFT terminals, Core Banking, Payment Gateways.	Fraudulent wire transfers, ransomware, insider threats.
Healthcare	Electronic Health Records (EHR), IoMT Medical Devices.	Ransomware locking ICU systems, unencrypted patient PII.
Energy & Power Grid	SCADA networks, Substation PLCs, Smart Meters.	State-sponsored sabotage, air-gap USB malware.

2. Economics, Finance, Banking & Healthcare Security

2.1 Economics of Cyber Security

Cybersecurity is fundamentally an economic problem where threat actors exploit asymmetric costs:

- **Asymmetric Cost Advantage:** Attackers require minimal capital investment to launch automated global exploits, whereas defenders incur high continuous operational costs to protect vast attack surfaces.
- **Return on Security Investment (ROSI):** Financial metric evaluating risk reduction value against defense control implementation costs:

$$\text{ROSI} = \frac{(\text{Risk Exposure} \times \text{Mitigation \%}) - \text{Solution Cost}}{\text{Solution Cost}}$$

2.2 SWIFT and Financial Network Security

The Society for Worldwide Interbank Financial Telecommunication (SWIFT) connects global financial institutions:

- **SWIFT Customer Security Controls Framework (CSCF):** Mandatory security controls regulating local bank terminal security, network segmentation, and credentials management (instigated after the \$81 Million Bangladesh Bank Heist).
- **Core Banking Security:** End-to-end hardware security modules (HSM) for PIN verification and transaction signing.

Real-World Case Study: Bangladesh Bank SWIFT Heist (2016)

1. **Infiltration Vector:** Attackers compromised local Bangladesh Bank terminal credentials using malware via unpatched network switches.
2. **Execution:** Issued 35 fraudulent SWIFT requests totaling \$951 Million to the Federal Reserve Bank of New York.
3. **Outcome:** Successfully transferred \$81 Million to casinos in the Philippines before a spelling error ('fandation' instead of 'foundation') alerted routing banks.

2.3 Healthcare Cybersecurity Safeguards

HIPAA Security Rule mandates three safeguard categories:

- **Administrative Safeguards:** Security management policies, risk analysis, employee security awareness training.
- **Physical Safeguards:** Facility access controls, workstation security, media disposal rules.
- **Technical Safeguards:** Access control, audit logs, automatic logoff, AES-256 data encryption at rest and in transit.

3. Cyber Insurance & Risk Transfer

Definition: Cyber Insurance Coverage Tiers

- **First-Party Coverage:** Directly reimburses the policyholder for forensic investigation costs, ransomware extortion payments, business interruption loss, and customer notification fees.
- **Third-Party Coverage:** Covers legal defense fees, settlements, and regulatory fines resulting from lawsuits by affected third-party customers.

3.1 Underwriting and Actuarial Challenges

1. **Systemic / Accumulation Risk:** A single zero-day bug (e.g. cloud outage) can trigger simultaneous claims across millions of policyholders, risking insurer insolvency.
2. **War Exclusion Clauses:** Insurers often deny payouts citing 'Act of War' clauses for state-sponsored attacks (e.g., NotPetya litigation).
3. **Moral Hazard:** Insured organizations relaxing security measures relying on insurance payouts.

4. Cyber Security in International Relations

Tallinn Manual Use of Force Escalation Thresholds

Cyber Intrusion
(Espionage
/ Recon)



Use of Force
(Article 2(4)
UN Charter)



Armed Attack
(Article 51
Self-Defense)

4.1 International Treaties and Frameworks

- **Tallinn Manual 2.0:** Non-binding study on applying international law to cyber operations, defining when a cyber attack constitutes an 'Armed Attack' under Article 51 of UN Charter.
- **Budapest Convention on Cybercrime (2001):** International treaty standardizing national cybercrime legislation and enabling cross-border digital evidence sharing.
- **UN GGE Norms:** Voluntary non-binding norms prohibiting states from damaging each other's critical infrastructure during peacetime.

Quick Revision — Module 4

Cyber Infrastructure Issues & International Relations | OE-EC803C

Key Concepts and Metrics at a Glance

SWIFT CSCF	Mandatory baseline controls for global banking messaging terminals.
HIPAA Safeguards	Administrative, Physical, and Technical controls for patient health data.
First-Party Insurance	Covers direct losses (forensics, downtime, ransomware payments).
Third-Party Insurance	Covers customer lawsuits and regulatory non-compliance fines.
Tallinn Manual 2.0	International legal manual defining cyber warfare armed attack thresholds.

One-Line Definitions

- **CNI:** Critical National Infrastructure vital for national security and public safety.
- **Systemic Risk:** Cascading failure across dependent entities from a single cyber event.
- **Budapest Convention:** International treaty facilitating cross-border cybercrime prosecution.
- **Article 51 UN Charter:** Inherent right of self-defense against armed cyber attacks.

Frequently Asked / Viva Questions

Q1. Define Critical National Infrastructure (CNI).

Systems and networks so vital that their incapacitation would paralyze national security, economy, or public safety.

Q2. Describe the Bangladesh Bank SWIFT heist of 2016.

Attackers used malware on local bank terminals to issue 35 fraudulent SWIFT requests, stealing \$81 Million.

Q3. Explain the 3 HIPAA safeguard categories for healthcare security.

Administrative Safeguards (policies), Physical Safeguards (facility controls), and Technical Safeguards (AES-256 encryption, access control).

Q4. What is the Tallinn Manual 2.0?

An authoritative study detailing how international law applies to cyber espionage, sovereignty, and state-sponsored cyber warfare.

Q5. Distinguish between First-Party and Third-Party Cyber Insurance.

Frequently Asked / Viva Questions (contd.)

First-party covers direct operational costs (forensics, ransomware, downtime);
Third-party covers customer lawsuits and regulatory fines.

Q6. What is Systemic Risk in cyber insurance underwriting?

The risk that a single zero-day exploit or cloud outage cascades across thousands of insured companies simultaneously.

Q7. What is the Budapest Convention on Cybercrime?

An international treaty harmonizing national cyber laws and facilitating cross-border digital evidence collection.

Q8. How does Article 51 of the UN Charter apply to cyber attacks.

Allows a state to exercise military self-defense if a cyber attack causes physical destruction or human casualties equivalent to an armed attack.

Q9. What are SWIFT CSCF mandatory controls?

Controls mandating network isolation of SWIFT terminals, strict MFA, and continuous transaction monitoring.

Q10. What is Moral Hazard in cyber insurance?

The tendency of an insured firm to reduce its security spending, relying on insurance payouts to handle breaches.

Q11. Explain the War Exclusion Clause in cyber insurance.

A clause allowing insurers to refuse payouts if a breach is attributed to a state-sponsored act of war.

Q12. What is the role of UN GGE in cyber diplomacy?

Developing non-binding international norms prohibiting states from conducting malicious cyber attacks against critical civilian infrastructure.

Q13. Why are connected medical devices (IoMT) vulnerable?

Because infusion pumps and MRI machines run unpatched embedded OSs, making them targetable by ransomware.

Q14. Define Operational Technology (OT).

Hardware and software that detects or causes physical changes through direct monitoring of industrial plant equipment.

Q15. What is the primary defense against SCADA air-gap bridging malware?

Strict USB port lockdown, disabling autorun, and scanning all external media before connecting to OT systems.

Summary Comparison: Infrastructure Security Requirements

Infrastructure Sector	Regulatory Standard	Primary Security Control	Main Operational Concern
Financial Banking	SWIFT CSCF / PCI-DSS	Hardware Security Modules (HSM)	Wire Fraud & Account Takeover
Healthcare	HIPAA Security Rule	Field-Level AES Encryption	Ransomware & Patient Safety
Energy Grid	NERC-CIP Standards	Purdue Level 3.5 Air Gap	Plant Sabotage & Blackouts
Transportation	NIST SP 800-82	Industrial Protocol Firewalls	Signaling Tampering